

Propuesta de Arquitectura

Sistema de Banca por Internet BP

Enfoque	Modelo C4 hasta nivel de componentes, complementado con flujos de autenticación, onboarding, auditoria e infraestructura.
Objetivo	Proponer una banca digital segura, disponible, trazable y preparada para evolucionar con nuevos productos financieros.
Nube propuesta	AWS multi-AZ con preparación para recuperación ante desastres multi-region.
Fecha	Abril de 2026.

Nota de alcance: la solución plantea una arquitectura de referencia. No desarrolla el producto OAuth ni el motor biométrico; los integra como capacidades especializadas con controles de seguridad y trazabilidad.

Contenido

1.	Introducción	4
2.	Vision de la solución	4
3.	Decisiones arquitectónicas principales	4
4.	Modelo C4	5
5.	Autenticación y autorización.....	7
6.	Onboarding móvil con reconocimiento facial.....	7
7.	Auditoria, trazabilidad y clientes frecuentes	8
8.	Infraestructura, alta disponibilidad y recuperación	9
9.	Seguridad, normativa y monitoreo	10
10.	Costos y operación	11
11.	Conclusiones	11
12.	Referencias	11

Ilustración 1 C4 Nivel 1 - Contexto del sistema.....	5
Ilustración 2 C4 Nivel 2 - Contenedores.....	6
Ilustración 3 C4 Nivel 3 - Componentes principales.....	6
Ilustración 4 Flujo de autenticación OAuth 2.0/OIDC con PKCE.....	7
Ilustración 5 Flujo de onboarding móvil con reconocimiento facial.	8
Ilustración 6 Patron de auditoría, Outbox y cache-aside.....	9
Ilustración 7 Despliegue cloud, alta disponibilidad y recuperación ante desastres.....	10

1. Introducción

BP necesita una plataforma de banca digital que permita a sus clientes consultar movimientos, realizar pagos, ejecutar transferencias entre cuentas propias e interbancarias, y recibir notificaciones de los movimientos realizados. La arquitectura debe integrarse con el Core bancario, con un sistema complementario de información del cliente y con proveedores externos como redes de pago, servicios biométricos y canales de notificación.

La propuesta busca equilibrar tres preocupaciones que en banca no pueden separarse: experiencia de usuario, seguridad y continuidad operativa. Por eso se plantea una arquitectura desacoplada por capacidades de negocio, con integración controlada, auditoría inmutable, observabilidad de extremo a extremo y mecanismos de recuperación ante fallos.

2. Vision de la solución

El sistema se organiza en canales digitales, una capa de borde seguro, servicios de dominio, una capa de integración y una base de datos especializada por responsabilidad. La SPA web y la aplicación móvil no se comunican directamente con el Core; lo hacen a través de un API Gateway, un BFF y servicios que encapsulan reglas de negocio.

Esta separación permite que cada parte tenga una responsabilidad clara. Los canales se concentran en la experiencia del cliente; los servicios de dominio resuelven operaciones bancarias; los adaptadores traducen contratos con sistemas internos y externos; y la mensajería permite procesar auditoría, notificaciones e invalidaciones de cache sin frenar la transacción principal.

Criterio de diseño: se prioriza una solución que pueda crecer sin volverse rígida. Nuevos productos, proveedores de notificación o canales futuros deberían agregarse mediante servicios y adaptadores, no modificando todo el sistema.

3. Decisiones arquitectónicas principales

La primera decisión es adoptar microservicios orientados a capacidades de negocio. Se evaluó un monolito modular y una SOA tradicional; ambas alternativas pueden funcionar, pero para este caso los dominios de consulta, pagos, transferencias, onboarding y notificaciones tienen ritmos de cambio y riesgos distintos. Separarlos mejora la cohesión, reduce acoplamientos y permite aislar fallos mediante timeouts, circuit breakers y colas.

La segunda decisión es usar un API Gateway junto con un BFF para los canales. Conectar la web o la app directamente al Core generaría dependencia fuerte con sistemas legados y haría difícil aplicar controles transversales. En cambio, el Gateway centraliza TLS, cuotas, validación de tokens, protección WAF y trazabilidad; el BFF reduce llamadas desde los canales y adapta las respuestas al contexto web o móvil.

Para la aplicación web SPA se recomienda Angular como framework principal. En un contexto bancario, Angular resulta conveniente porque ofrece una estructura integral y estandarizada para aplicaciones empresariales, incluyendo enrutamiento, formularios reactivos, cliente HTTP, inyección de dependencias, popularización y soporte robusto para pruebas. Esto facilita el gobierno técnico, la mantenibilidad y la incorporación de múltiples equipos de desarrollo bajo convenciones comunes. React también es una alternativa válida por su flexibilidad y ecosistema, pero requiere definir e integrar más decisiones arquitectónicas desde el inicio, lo cual puede aumentar la variabilidad entre equipos si no existe una guía interna estricta. Para la aplicación móvil se recomienda Flutter, porque ofrece una experiencia consistente entre iOS y Android, buen rendimiento visual y un único codebase para flujos complejos como onboarding con cámara y biometría.

En autenticación, la recomendación es usar OpenID Connect sobre OAuth 2.0 con Authorization Code Flow y PKCE. Se descarta el flujo implicit para nuevas aplicaciones y también se evita capturar credenciales directamente en los canales.

Este enfoque permite MFA, step-up authentication, rotación de refresh tokens, control de sesiones y scopes granulares para operaciones como consulta, transferencias y pagos.

Para los procesos no sincrónicos se propone una arquitectura orientada a eventos. La auditoría, las notificaciones y la actualización de cache no deben depender de llamadas frágiles en el camino crítico. El patrón Transactional Outbox ayuda a garantizar que, si una operación se confirma, el evento asociado también será publicado de forma confiable.

Finalmente, la información de clientes frecuentes se maneja con cache-aside y vistas materializadas. El Core sigue siendo la fuente de verdad, especialmente para saldos y autorización de transacciones, pero Redis permite mejorar la latencia en consultas frecuentes sin sacrificar consistencia bancaria.

4. Modelo C4

El modelo C4 permite explicar la solución con distintos niveles de detalle. Primero se muestra el contexto para lectores no técnicos; luego los contenedores para entender aplicaciones, servicios y datos; finalmente los componentes para detallar patrones, protocolos y responsabilidades internas.

C4 Nivel 1 - Contexto BP Digital

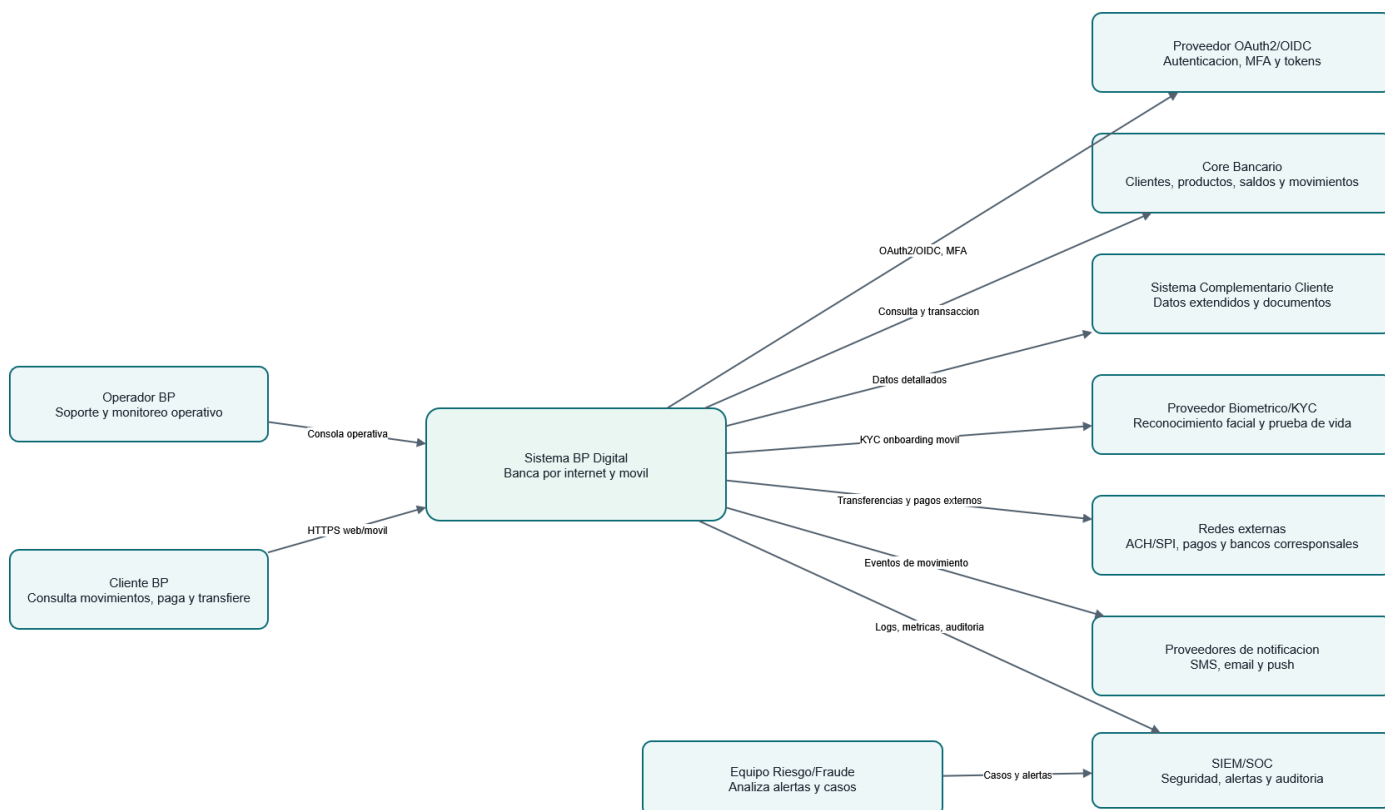


Ilustración 1 C4 Nivel 1 - Contexto del sistema.

En el contexto general, BP Digital actúa como punto de entrada para los clientes, pero no reemplaza a los sistemas centrales. Consulta al Core para productos, movimientos y saldos; consulta el sistema complementario cuando requiere información detallada; se apoya en un proveedor OAuth/OIDC para identidad; usa servicios biométricos para onboarding; y envía notificaciones por múltiples canales.

C4 Nivel 2 - Contenedores

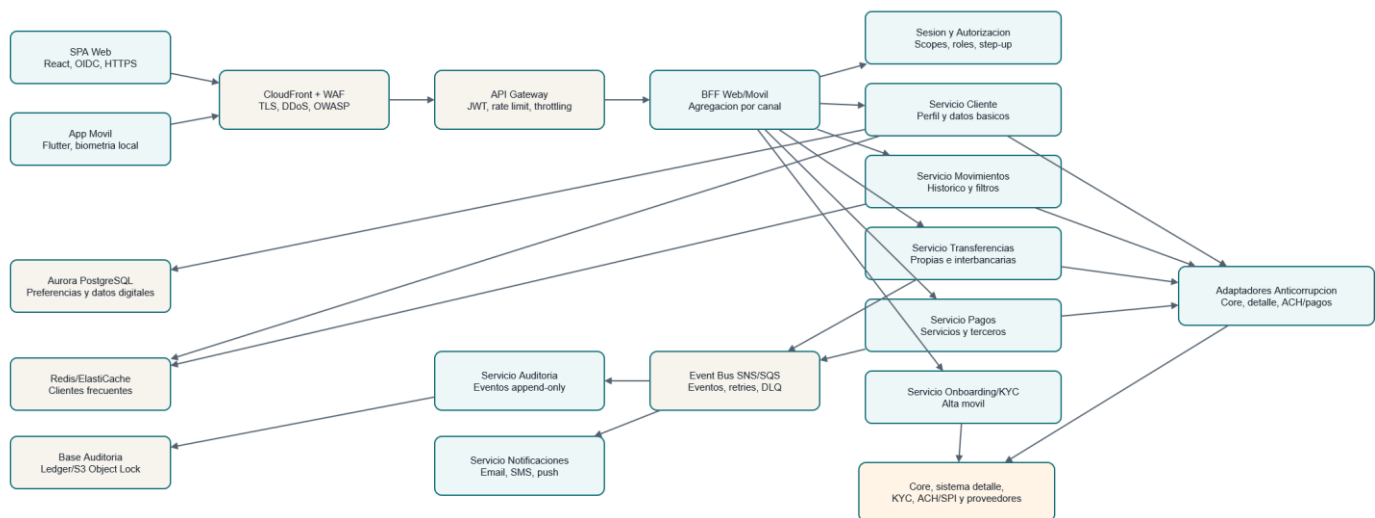


Ilustración 2 C4 Nivel 2 - Contenedores.

En el nivel de contenedores se observa la separación entre canales, borde seguro, BFF, servicios de dominio, mensajería, bases de datos y adaptadores. Esta división permite escalar de forma independiente las capacidades más demandadas, por ejemplo, consultas de movimientos o notificaciones, sin afectar el resto de la plataforma.

C4 Nivel 3 - Componentes

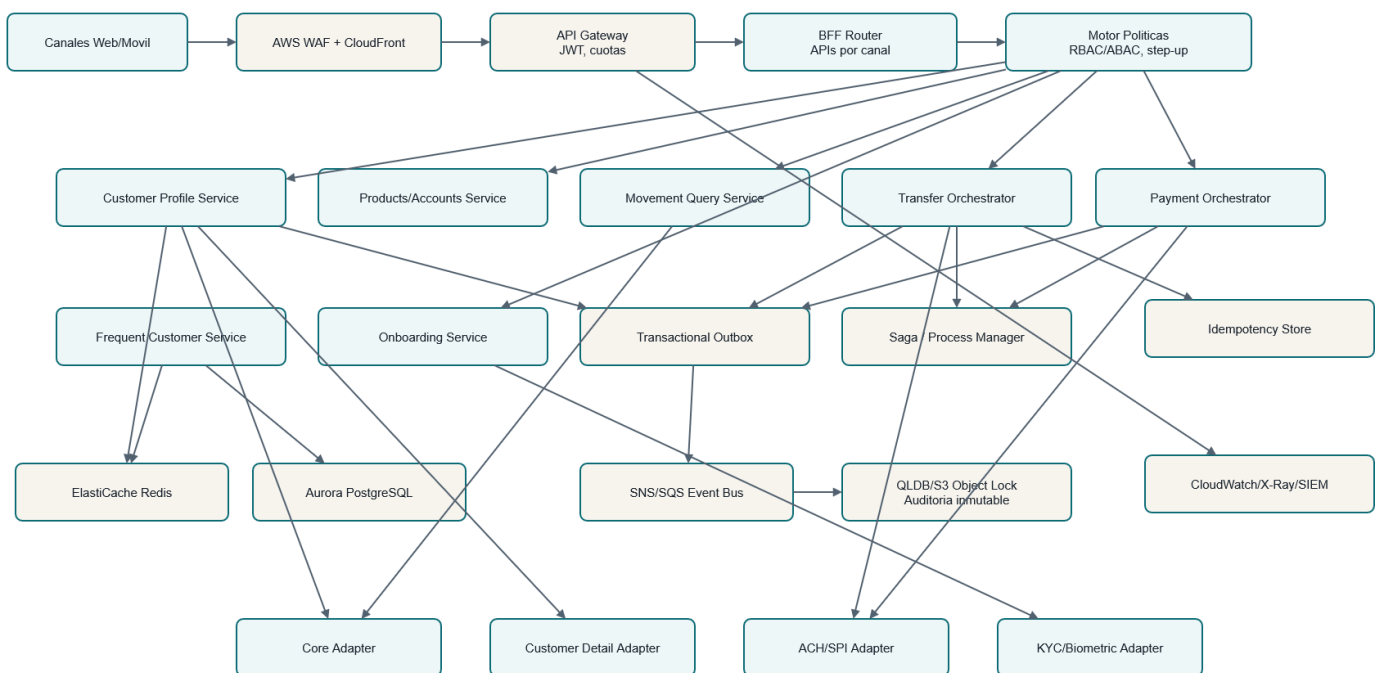


Ilustración 3 C4 Nivel 3 - Componentes principales.

El nivel de componentes muestra los mecanismos técnicos que hacen robusta la arquitectura: validación de tokens, motor de políticas, idempotencia, saga para procesos de transferencias y pagos, Outbox para publicación confiable, circuit breakers para integraciones externas y observabilidad transversal.

5. Autenticación y autorización

La autenticación se apoya en un producto OAuth/OIDC existente en la compañía. La mejor recomendación para SPA y aplicación móvil es Authorization Code Flow con PKCE. En este flujo, el cliente no envía usuario y clave a la aplicación; es redirigido al proveedor de identidad, donde se aplican reglas de MFA, riesgo y políticas corporativas.

Las operaciones sensibles deben solicitar step-up authentication. Por ejemplo, una consulta de saldo podría requerir solo una sesión válida, pero una transferencia a un nuevo beneficiario debería exigir un segundo factor, validación de dispositivo o aprobación push. Este enfoque reduce fricción en operaciones simples y eleva la seguridad cuando el riesgo aumenta.

Flujo de Autenticación OAuth 2.0/OIDC con PKCE

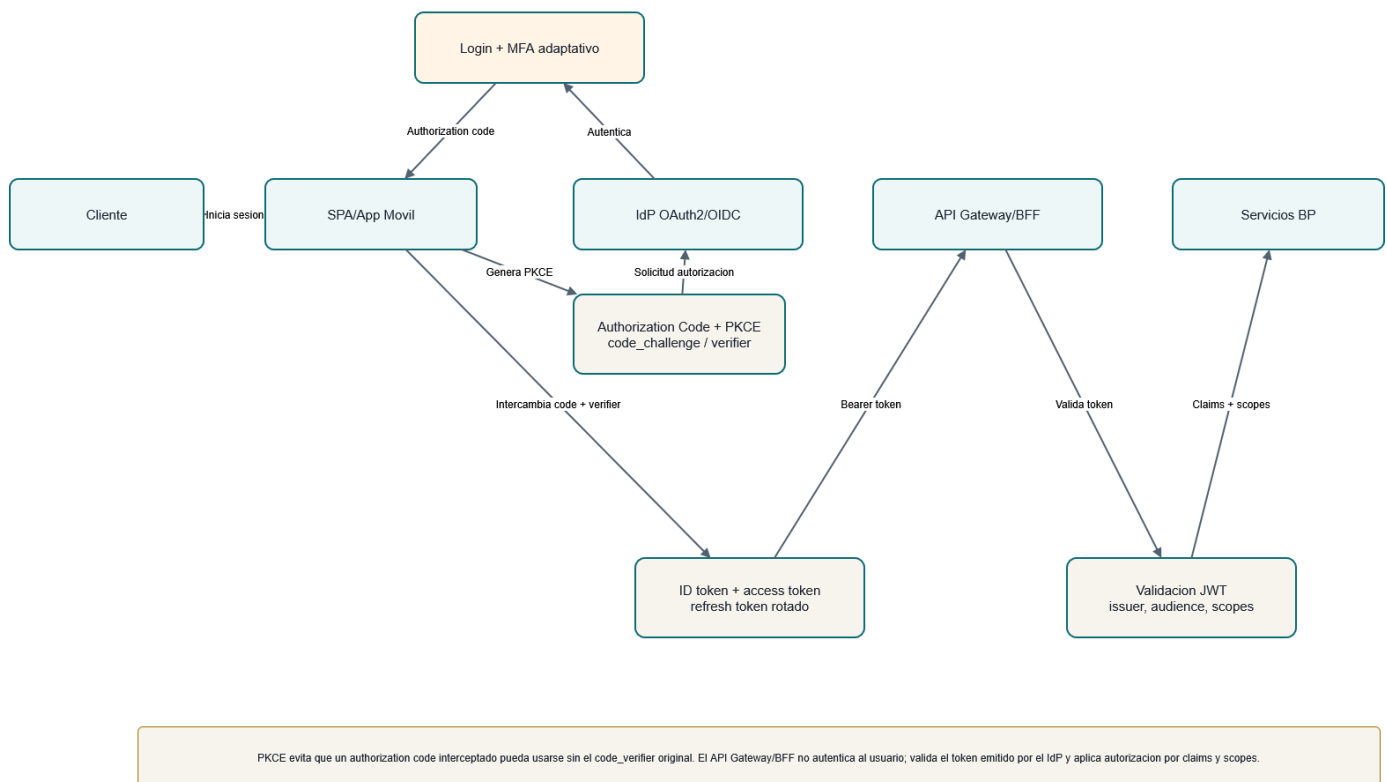


Ilustración 4 Flujo de autenticación OAuth 2.0/OIDC con PKCE.

- Tokens de corta duración y refresh tokens con rotación.
- Scopes separados para lectura de cuentas, lectura de movimientos, pagos y transferencias.
- Validación estricta de issuer, audience, expiración, firma y permisos.
- Almacenamiento seguro de credenciales en la app móvil mediante Keystore o Secure Enclave.

6. Onboarding móvil con reconocimiento facial

El onboarding debe tratarse como un flujo de autorización inicial y no como un simple registro. La app móvil captura documento y rostro, el servicio de onboarding coordina la validación con un proveedor biométrico, y un motor antifraude evalúa señales como dispositivo, IP, listas restrictivas y consistencia documental.

Si el resultado es aprobado, el sistema crea o actualiza el cliente en el Core, registra el alta en auditoría y enrola credenciales en el IdP. Para robustecer la solución se recomienda evaluar proveedores especializados como iProov, Onfido/Entrust, Jumio o FacePhi, debido a que ofrecen capacidades maduras de verificación de identidad digital, reconocimiento facial, prueba de vida, validación documental y soporte para procesos KYC. Estas herramientas permiten reducir el riesgo de suplantación durante el onboarding, mejorar la experiencia del cliente y apoyarse en soluciones ya probadas en industrias reguladas. La selección final debe considerar cobertura regional, cumplimiento normativo, precisión biométrica, privacidad de datos, facilidad de integración, costos, soporte local y capacidad de auditoría.

Onboarding Movil con Reconocimiento Facial

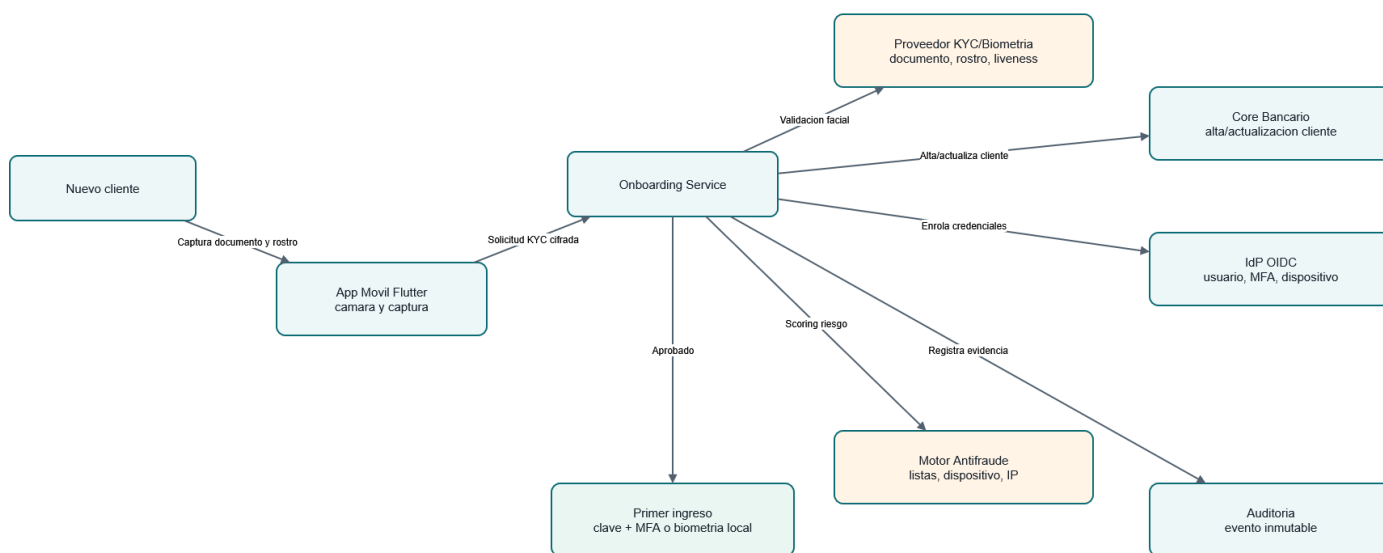


Ilustración 5 Flujo de onboarding móvil con reconocimiento facial.

Una vez finalizado el onboarding, el cliente podrá ingresar a la aplicación utilizando usuario y clave, reforzado con un segundo factor de autenticación cuando el nivel de riesgo lo requiera. También podrá habilitar el ingreso con biometría del dispositivo, como huella o reconocimiento facial. En este caso, la biometría no reemplaza al servicio central de identidad del banco, sino que funciona como un mecanismo seguro para desbloquear una credencial previamente registrada o aprobar un reto de autenticación asociado a un dispositivo confiable.

7. Auditoria, trazabilidad y clientes frecuentes

En cualquier sistema, la auditoria no es un complemento: es parte del producto. Cada acción relevante debe registrarse con actor, canal, fecha, IP, dispositivo, resultado, identificador de correlación y evidencia mínima necesaria. Para evitar manipulaciones, la base de auditoria debe ser append-only y, cuando aplique, almacenarse con mecanismos WORM.

El patrón Transactional Outbox evita una falla común: confirmar una transferencia y perder el evento de auditoria o notificación. La transacción guarda el cambio y el evento pendiente en la misma base; luego un publicador confiable envía el evento al bus. Si el proveedor de notificaciones falla, el evento queda en cola, se reintenta y puede ir a una DLQ para gestión operativa.

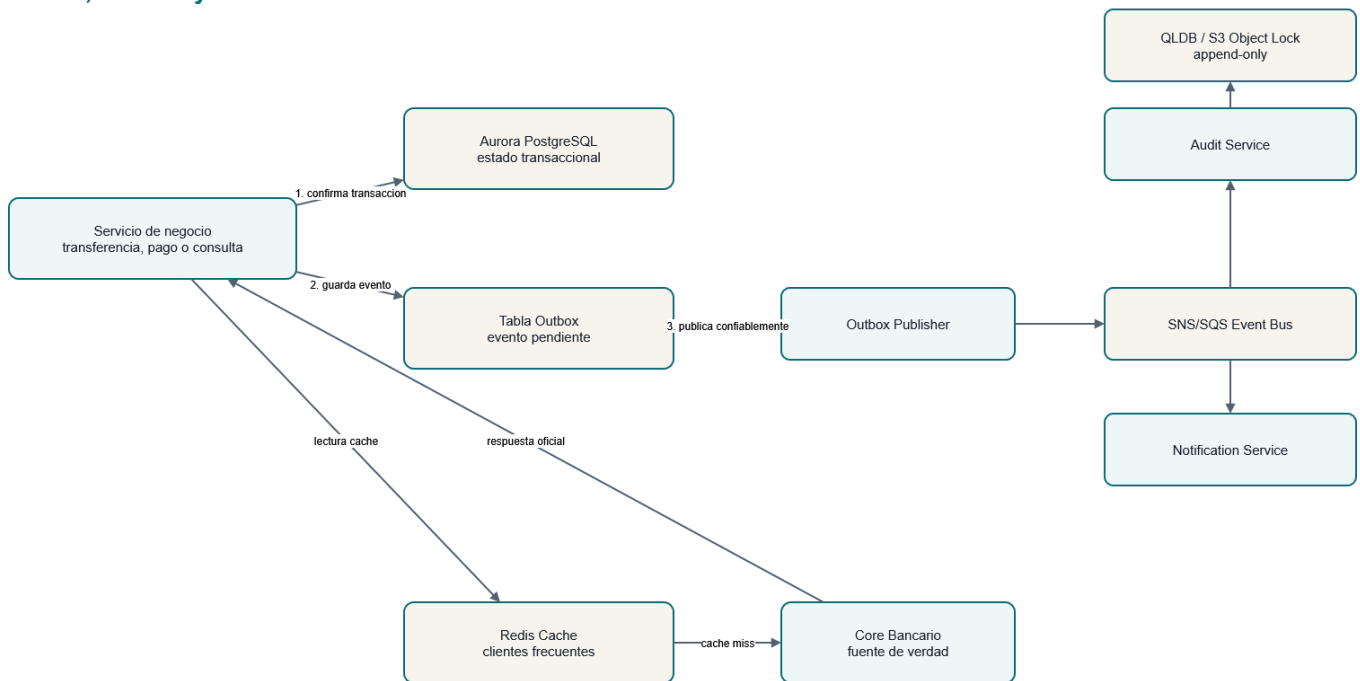


Ilustración 6 Patrón de auditoría, Outbox y cache-aside.

Para clientes frecuentes se recomienda cache-aside. Cuando el cliente consulta información frecuente, el servicio busca primero en Redis. Si no existe o expiro, consulta al Core, responde y actualiza el cache con TTL. Este mecanismo mejora la experiencia sin convertir el cache en fuente de verdad para decisiones criticas como saldos definitivos o autorización de débitos.

8. Infraestructura, alta disponibilidad y recuperación

Para ejecutar los microservicios se propone utilizar contenedores administrados en AWS. En caso de que BP ya tenga experiencia operando Kubernetes, Amazon EKS sería una buena opción por su flexibilidad y nivel de control. Si el objetivo es simplificar la operación y reducir la administración de infraestructura, Amazon ECS con Fargate puede ser más conveniente, porque permite desplegar los servicios sin gestionar servidores directamente. En ambos casos, la arquitectura puede operar en varias zonas de disponibilidad para mejorar la resiliencia del sistema.

Para reducir latencia y proteger el borde se incorporan Route 53, CloudFront, WAF y Shield. La conexión con el Core y sistemas internos debe realizarse por VPN o Direct Connect, con mTLS y segmentación de red. Para proveedores externos se usan endpoints HTTPS seguros, llaves rotadas y circuit breakers.

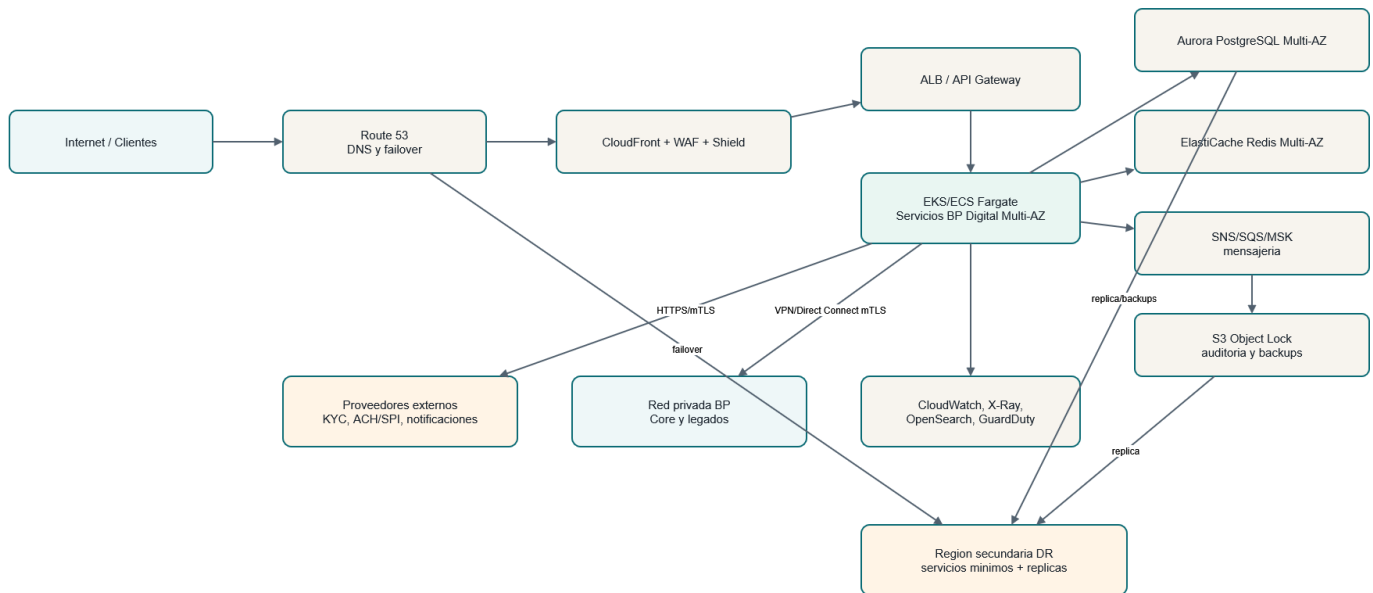


Ilustración 7 Despliegue cloud, alta disponibilidad y recuperación ante desastres.

Como objetivos iniciales se propone una disponibilidad mensual de 99.95% para consultas y 99.9% para transacciones, un RPO cercano a 15 minutos para datos digitales y un RTO de hasta 2 horas para los canales críticos. Estos valores deben validarse con BP según la criticidad de cada servicio, el presupuesto disponible, las exigencias regulatorias, la capacidad de recuperación del Core bancario y los acuerdos con proveedores externos. Si BP requiere un RTO menor, será necesario mantener una región secundaria más preparada, automatizar la conmutación, replicar datos de forma continua y realizar pruebas periódicas de recuperación.

9. Seguridad, normativa y monitoreo

La solución debe considerar la Ley Orgánica de Protección de Datos Personales, principios de minimización, consentimiento, finalidad, seguridad, retención y derechos del titular. También debe alinearse con normas de seguridad de información, continuidad, riesgo operativo, gestión de terceros y auditoría aplicables a entidades financieras supervisadas.

Desde la seguridad de aplicaciones se recomienda usar guías reconocidas como OWASP ASVS (Application Security Verification Standard) para aplicaciones web y APIs, y OWASP MASVS (Mobile Application Security Verification Standard) para aplicaciones móviles. Además, el proceso de desarrollo debe incluir SAST (Static Application Security Testing) para análisis de código, DAST (Dynamic Application Security Testing) para pruebas de seguridad sobre la aplicación en ejecución, revisión de librerías vulnerables, protección con WAF (Web Application Firewall), endurecimiento de la app móvil, cifrado de datos en tránsito y en reposo, administración segura de llaves mediante KMS (Key Management Service) y manejo protegido de credenciales con Secrets Manager.

El monitoreo debe cubrir métrica técnica y métrica de negocio. No basta con saber que un servicio responde; también se debe conocer cuántos logins fallan, cuantas transferencias son rechazadas, cuanto tarda un onboarding y cuantos eventos llegan a DLQ. La trazabilidad con correlation-id desde el canal hasta el Core es esencial para soporte, auditoria y respuesta a incidentes.

10. Costos y operación

El control de costos se apoya en autoscaling, límites por servicio, retención diferenciada de logs y trazas, TTL en cache, particionamiento de auditoría y almacenamiento histórico en clases de menor costo. Para DR se propone un piloto tibio en región secundaria, que ofrece mejor tiempo de recuperación que solo backups, sin el costo de mantener una región completa activa-activa desde el inicio.

La solución debe operarse con procesos automatizados, pruebas, documentación y objetivos claros. Además, debe probarse bajo escenarios de falla reales para asegurar que pueda recuperarse y seguir funcionando incluso cuando fallen componentes externos o internos.

11. Conclusiones

La propuesta satisface los requerimientos iniciales y plantea una base sólida para una banca digital moderna. El diseño separa responsabilidades, reduce acoplamientos con sistemas legados, incorpora autenticación fuerte, onboarding biométrico, auditoría confiable, mensajería asíncrona, alta disponibilidad y recuperación ante desastres.

La recomendación final es construir la plataforma de forma incremental: primero identidad, consultas, auditoría y notificaciones; luego transferencias y pagos con idempotencia y saga; y finalmente optimizaciones de cache, antifraude y analítica operacional. Así BP obtiene valor temprano sin comprometer seguridad ni trazabilidad.

12. Referencias

- C4 Model: <https://c4model.com/>
- IETF RFC 9700, OAuth 2.0 Security Best Current Practice: <https://datatracker.ietf.org/doc/html/rfc9700>
- Ley Orgánica de Protección de Datos Personales: <https://www.registroficial.gob.ec/267223-2/>
- Superintendencia de Bancos - Codificación de normas: <https://www.superbancos.gob.ec/bancos/codificacion-de-normas-de-la-sb-libro-uno-sistema-financiero/>
- OWASP ASVS/MASVS: <https://owasp.org/>
- AWS Well-Architected Framework: <https://aws.amazon.com/architecture/well-architected/>